Digital Personal Data Protection Act, 2023 (India) — Operational Impact Summary

Internal reference document — not a legal opinion. Prepared by Legal & Compliance Office. For executive briefing on 2026 operational compliance.

1. Act Overview

The Digital Personal Data Protection Act, 2023 (DPDP Act) is India's comprehensive data protection law, with phased implementation through 2026. Rules notified by MeitY in late 2025 trigger operational obligations in Q1 2026. This document summarizes obligations most relevant to BFSI operations.

2. Key Obligations

Consent: Obtain specific, informed, free, and unambiguous consent from Data Principals before processing their personal data for defined purposes. Consent must be in English or any of the 22 scheduled Indian languages. Withdrawal must be as easy as granting.

Purpose Limitation: Personal data shall be processed only for the specific purpose for which consent was given. New purposes require fresh consent.

Data Minimization: Collect only personal data necessary for the specified purpose. Over-collection is a violation.

Breach Notification: Report personal data breaches to the Data Protection Board of India AND affected Data Principals within 72 hours. Delay invites penalties up to ■250 crore per violation.

Data Principal Rights: Right to access, correction, erasure, grievance redressal, and nomination. Response within 30 days (unless exempted class).

Children's Data: Verifiable parental consent required for anyone under 18. Behavioral monitoring and targeted advertising to children prohibited.

Significant Data Fiduciaries: Entities notified as SDFs (based on volume, sensitivity, risk) have additional obligations: DPO appointment, DPIA, independent audit, data audit.

Cross-Border Transfer: Transfer of personal data outside India permitted only to countries notified by the Central Government. Restricted countries list to be notified.

Retention: Personal data shall not be retained beyond the purpose for which it was collected unless required by law. Default: delete when purpose is served.

Grievance Redressal: Data Fiduciary must publish contact details of a grievance officer. Response within prescribed period (notified rules).

3. Penalty Structure

Violation	Maximum Penalty
Failure to notify data breach	■200 crore
Failure in reasonable security safeguards	■250 crore
Non-fulfillment of children's data obligations	■200 crore
Non-fulfillment of SDF obligations	■150 crore
Breach of other obligations	■50 crore
False information to Board	■10 crore

4. Implementation Timeline (per MeitY notified rules, Oct 2025)

Phase 1 (effective 1-Jan-2026): consent management, grievance officer, breach notification mechanism.

Phase 2 (effective 1-Jul-2026): data principal rights workflow, retention policy enforcement, DPO appointment for SDFs.

Phase 3 (effective 1-Jan-2027): cross-border transfer restrictions, DPIA for high-risk processing, independent data audit.

5. Compliance Checkpoints (what regulators will test)

• Consent artifact — is explicit, documented, timestamped consent captured per processing purpose?

• Purpose binding — is each data processing operation tagged to its original consent purpose?

• 72-hour breach detect and notify — is there a documented, tested breach-detection and notification workflow?

• Erasure request fulfillment — can the organization erase a Data Principal's data within 30 days of request, including from backups?

• Children's data verification — is there a tested age-gating mechanism before data collection?

• Grievance officer response — is a grievance officer named, contactable, and responding within statutory period?

• Retention enforcement — is personal data actually deleted when its purpose is served, or only marked for deletion?

References: Digital Personal Data Protection Act, 2023 (Act 22 of 2023); MeitY Notification G.S.R. 1217(E) dated 15 October 2025; Draft Rules under consultation 2024.